

Лабораторна робота № 10. Виявлення та аналіз веб-вразливостей у середовищі OWASP Juice Shop

Мета роботи. Набуття практичних навичок виявлення, аналізу та експлуатації вразливостей веб-додатків відповідно до OWASP Top 10 з використанням OWASP Juice Shop.

Теоретичні відомості

OWASP Juice Shop — це навмисно вразливий веб-додаток, який моделює реальні сценарії атак. Він містить широкий спектр уразливостей, зокрема:

- Injection (SQL, Command Injection)
- Broken Authentication
- Sensitive Data Exposure
- Broken Access Control
- Cross-Site Scripting (XSS)
- Security Misconfiguration

Робота з Juice Shop передбачає підхід **Capture the Flag (CTF)**: студент виконує завдання, експлуатуючи вразливості.

Необхідне програмне забезпечення

Перед виконанням роботи студент повинен встановити:

- Node.js (або Docker)
- OWASP Juice Shop
- Браузер (Chrome/Firefox)
- Інструменти тестування (рекомендовано):
 - Burp Suite / OWASP ZAP
 - Postman (опціонально)

Порядок виконання лабораторної роботи

1. Розгортання середовища

1. Встановіть Juice Shop:
 - через Node.js:

```
git clone https://github.com/juice-shop/juice-shop.git
cd juice-shop
```

```
npm install  
npm start
```

- або через Docker:

```
docker run -d -p 3000:3000 bkimminich/juice-shop
```

2. Відкрийте додаток у браузері:

<http://localhost:3000>

2. Ознайомлення з інтерфейсом

Проаналізуйте:

- структуру веб-додатку;
- основні функції (реєстрація, логін, покупки);
- механізм підказок (Score Board).

3. Виконання практичних завдань

Студент повинен виконати серію завдань (мінімум 5–8), наприклад:

Завдання 1. Аналіз автентифікації

- проаналізуйте форму логіну;
- спробуйте обійти автентифікацію (SQL Injection).

Завдання 2. XSS-атака

- знайдіть поле введення (наприклад, відгуки);
- реалізуйте reflected або stored XSS.

Завдання 3. Broken Access Control

- спробуйте отримати доступ до ресурсів без авторизації;
- змініть параметри запиту (IDOR).

Завдання 4. Sensitive Data Exposure

- знайдіть приховані дані (API, конфігурації);
- використайте DevTools.

Завдання 5. API-аналіз

- перехопіть HTTP-запити через Burp Suite;
- модифікуйте запити.